AI 安全與道德治理

結合 dual_model、Agent 影響限制與 OpenWorkProof 的可驗證 AI SOC 架構

AI SOC and AI Agent Escape Defense: Dual-Model Detection, External Authorization, and Verifiable Governance

Tim Shing · Deng Yier

OpenWorkProof｜作者專案紀錄

研究設計論文｜優化稿 v2.0｜2026-11-01。採 IEEE 式論述及編號引用，非任何特定 IEEE 會議之官方版型。機構、通訊作者與作者貢獻未提供，故不代填。

摘要

本文研究兩個相連問題：AI-IDPS 的資料集表現如何連結真實未知攻擊防禦，以及工具型 Agent 的指令混淆、越權請求與執行域失守應如何分層治理。本文先分析傳統防禦的能力邊界，再提出 dual_model 與 OpenWorkProof 導向 AI SOC：監督模型識別已知模式，正常行為模型提供異常訊號；調查 Agent 關聯證據，但授權、簽章、實際執行與審計分屬外部信任域。研究將未知威脅偵測、操作合法性、隔離完整性與證據可驗證性分開定義，並把高影響處置的人類保留權、最小資料使用、覆核與申訴納入協定。本文提供兩張架構圖、條件式安全主張、對照基線、消融及可重現評估方案；不新增實測結果，不聲稱零日免疫或無條件防逃逸。

關鍵詞：AI-IDPS；dual_model；AI Agent escape；間接提示注入；最小權限；OpenWorkProof；人類自主權；可驗證審計。

I. 緒論

研究目的不是令單一模型「包辦安全」，而是建立可檢驗的職責分離：模型可出錯，Agent 可被誤導，但高影響動作仍須跨越可獨立驗證的授權邊界。本文依序論證既有方法能做甚麼、何時失效、我們的整合設計增加甚麼，以及如何以實驗推翻或支持該設計。

II. 傳統 AI 防禦：能力、假設與邊界

Sommer 與 Paxson（2010，IEEE S&P）指出，入侵偵測面對開放環境與活動多樣性，與一般封閉世界分類不同；Arp 等人（2022，USENIX Security）則整理了安全機器學習中資料、假設與評估的常見陷阱。[1][1][2][2]

表 I　方法選項與營運取捨。成本為相對工程判斷，非相同硬件上的實測排名。

方法	假設與優點	失效情境	部署成本
簽名／規則	已知特徵可精確描述；便於檢查規則命中。	缺乏新模式；規則例外可能失控。	推理低；規則維護中。
監督分類	標籤與部署環境具代表性；適合既知類別。	分佈改變、捷徑特徵、錯誤標籤。	算力低至中；標註高。
異常／開放集	正常基線可信；可對未見模式提出警報。	合法新行為誤報；正常基線污染。	算力中；覆核與基線維護高。

[1]R. Sommer and V. Paxson, “Outside the Closed World: On Using Machine Learning for Network Intrusion Detection,” IEEE Symposium on Security and Privacy, 2010. https://www.icir.org/vern/papers/ml-ids-oakland-10.pdf

[2]D. Arp et al., “Dos and Don’ts of Machine Learning in Computer Security,” USENIX Security, 2022. https://www.usenix.org/conference/usenixsecurity22/presentation/arp

方法	假設與優點	失效情境	部署成本
行為／互動圖	關聯遙測完整；能捕捉跨連線行為。	缺失資料、低可觀測性、窗口延遲。	中至高；需保存狀態。
LLM 調查 Agent	工具、上下文與證據可用；整合案件敘事。	注入、無證據結論、工具濫用。	算力與排隊中至高；需權限管理。
混合＋外部政策	偵測、授權與審計責任分離。	旁路或多個信任域共同失守。	整合及獨立運維成本較高。

A. 三種不可互換的成功

「正確辨識」是統計效能；「未授權動作未被執行」是控制效能；「第三方可驗證事件記錄」是證據效能。本文不允許以其中任何一項通過，宣稱另外兩項亦已獲得保證。即使分類正確，也可能因批准太慢而未及阻止損害；即使簽章完整，錯誤處置亦可能已發生。

B. Zero-day 的嚴格用語

本文區分未見樣本、未見攻擊家族、跨環境／跨時間泛化與此前未知漏洞利用。Leave-one-family-out 只測試所定義家族的外推，不證明發現真正未知漏洞。攻擊類別標籤亦可能混合多種漏洞或工具，因此需記錄家族分組依據。

C. 可觀測性與告警疲勞

異常不等於惡意，分類分數不等於已校準風險。若可見特徵不含區分訊號，增加模型層數未必有幫助。真實 SOC 應先以每日案件與分析師容量界定誤報預算，再選門檻；不能僅以 Accuracy 或未附 FPR 的 AUC 證明可部署。

III. 文獻結果與整合缺口（2023–2026）

本稿採目的性敘述綜述，核對作者頁、會議頁、預印本與官方機構說明；截止 2026-11-01，不涵蓋其後發表。並非 PRISMA 系統綜述，未聲稱完整檢索、雙人盲篩或元分析。2010–2022 文獻只作傳統方法與評估背景，近期研究主體為 2023–2026。

Mirsky 等人（2018，NDSS）的 Kitsune 以 Autoencoder 集成提供線上異常偵測路徑，適合作正常行為分支的先行工作，而非本文的新演算法。[3][3]

Fu、Li 與 Xu（2023，NDSS）的 HyperVision 以流量互動圖辨識未知加密惡意模式，作者在 92 個資料集、48 類攻擊的實驗中報告至少 0.92 AUC 與 0.86 F1。這是原作者環境結果，不是本文數字，也不能直接推論成低 FPR、所有未知漏洞或 ML4 的表現。[4][4]

Han 等人（2023，NDSS）的 OWAD 討論正常分佈轉移的偵測、解釋與適應，提醒異常模型需要區分正常改變與攻擊。本文因此把漂移處理與模型更新納入離線審核，而非讓 Agent 自動把新流量吸收成正常。[5][5]

[3]Y. Mirsky, T. Doitshman, Y. Elovici, and A. Shabtai, “Kitsune: An Ensemble of Autoencoders for Online Network Intrusion Detection,” NDSS, 2018; arXiv:1802.09089. https://arxiv.org/abs/1802.09089

[4]C. Fu, Q. Li, and K. Xu, “Detecting Unknown Encrypted Malicious Traffic in Real Time via Flow Interaction Graph Analysis,” NDSS, 2023. https://www.ndss-symposium.org/ndss-paper/detecting-unknown-encrypted-malicious-traffic-in-real-time-via-flow-interaction-graph-analysis/

[5]D. Han et al., “Anomaly Detection in the Open World: Normality Shift Detection, Explanation, and Adaptation,” NDSS, 2023; 年份以 NDSS 2023 議程確認。 https://www.ndss-symposium.org/ndss2023/accepted-papers/

Greshake 等人（2023，ACM AISec）研究外部內容導致的間接提示注入；Zhan 等人（2024，Findings of ACL）的 InjecAgent 以 1,054 個案例評估工具型 Agent。這些研究支持把 SOC 日誌與工具輸出視為不可信資料，但不是主機沙箱逃逸的同類測試。[6][6][7][7]

Debenedetti 等人（2024，NeurIPS）的 AgentDojo 提供 97 項任務與 629 項安全測試，要求同時觀察正常任務效用與攻擊影響；其 CaMeL 預印本（2025）進一步把資料流、控制流與能力政策置於模型外。本稿以所核對版本列示，不把預印本假設擴張成通用隔離證明。[8][8][9][9]

Marchand 等人（2026，SandboxEscapeBench 預印本）研究已具容器內 shell 能力的 Agent 是否能突破容器。UK AISI 說明其 18 個情境與巢狀隔離；所有成功突破均利用已披露弱點。此證據不等於任意硬化環境必被突破，也不代表 ML4 已獲相同測試結果。[10][10][11][11]

A. 本文提出的研究增量

上述研究分別處理偵測、提示注入、資料／控制流隔離或容器突破。本稿的研究增量是將 dual_model 案件證據、模型調查、事前授權、實際執行、外部見證與人類驗收綁定在同一 SOC 工作流，再以消融測試其相互作用。這是候選系統貢獻，不能在未做完整先行研究與實驗前宣稱首創或優於現有系統。

IV. 問題定義、威脅模型與治理假設

保護資產包括敏感遙測、模型與正常基線、工具能力、私鑰、批准權、執行回執及審計歷史。攻擊者可污染外部文字、提出越權請求，或取得內層執行域控制；不把模型對齊視為權限邊界。

表 II　威脅分層。此分類為本文分析工具，不是既有認證等級。

層級	假設的攻擊能力	剩餘可信控制
L0 內容污染	控制日誌、URL、附件或工具輸出的欄位。	資料／控制分離、工具政策、來源驗證。
L1 Agent 被控制	令 Agent 提出惡意或越權操作。	模型外授權、精確參數驗證、人類保留權。
L2 內層失守	取得容器／內層 microVM 域內控制。	若外層仍可信：獨立網絡、宿主邊界、PEP、審計。
L3 信任根失守	控制宿主、簽章／政策服務或其管理身份。	不承諾原有預防保證；依外部見證與應變恢復。

[6] K. Greshake et al., “Not what you’ve signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection,” ACM AISec, 2023; arXiv:2302.12173. https://arxiv.org/abs/2302.12173

[7] Q. Zhan, Z. Liang, Z. Ying, and D. Kang, “InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents,” Findings of ACL, 2024; arXiv:2403.02691. https://arxiv.org/abs/2403.02691

[8] E. Debenedetti et al., “AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents,” NeurIPS Datasets and Benchmarks, 2024; arXiv:2406.13352. https://arxiv.org/abs/2406.13352

[9] E. Debenedetti et al., “Defeating Prompt Injections by Design,” arXiv:2503.18813, 2025, v2. 本稿以所核對預印本為準，不推定後續會議發表狀態。 https://arxiv.org/abs/2503.18813

[10] A. Marchand et al., “Can AI Agents Escape Their Sandboxes? A Benchmark for Evaluating Container Breakout Capabilities,” arXiv:2603.02277, 2026, v3. 本稿按預印本列示。 https://arxiv.org/abs/2603.02277

[11] UK AI Security Institute, “Can AI agents escape their sandboxes? A benchmark for safely measuring container breakout capabilities,” 23 March 2026, 官方技術說明，非另一次獨立實驗。 https://www.aisi.gov.uk/blog/can-ai-agents-escape-their-sandboxes-a-benchmark-for-safely-measuring-container-breakout-capabilities

A. 逃逸一詞必須註明邊界

若「逃逸」指突破容器，宿主與外部政策可能仍提供限制；若已突破宿主或控制網絡執行點，不能再聲稱容器內無憑證即可保證安全。圖 2 以可失守的內層執行域 A、外部服務域 C 及獨立審計域 B 表示此差異。

B. 核心信任假設

所有受保護動作必經不可繞過的 PEP；工具與資源身份可驗；外部政策與簽章服務未被同時控制；私鑰不在 Agent 執行域；單次使用及撤銷狀態保持一致；審計管理員與沙箱管理員具實質分離。不同進程、帳戶或命名空間本身不足以證明上述獨立性，需核對管理身份及可達路徑。

C. 治理不是事後加一個簽名

NIST AI RMF 1.0（2023）以 GOVERN、MAP、MEASURE、MANAGE 組織風險工作。本文把負責人、用途限制、量測、回退、人類否決與申訴轉換成系統需求；這只是設計對照，不等於取得 NIST 認證、法規合規或法律責任裁決。[12][12]

核心立場為：不假設 Agent 永遠可信，而是令其請求必須接受外部授權與證據檢查。本文不使用「逃逸後每一步絕對無法偽造、無法越權、無法抹去」作無條件主張。

[12]NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, January 2023. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf

V. 提出架構一：dual_model 訓練與推理

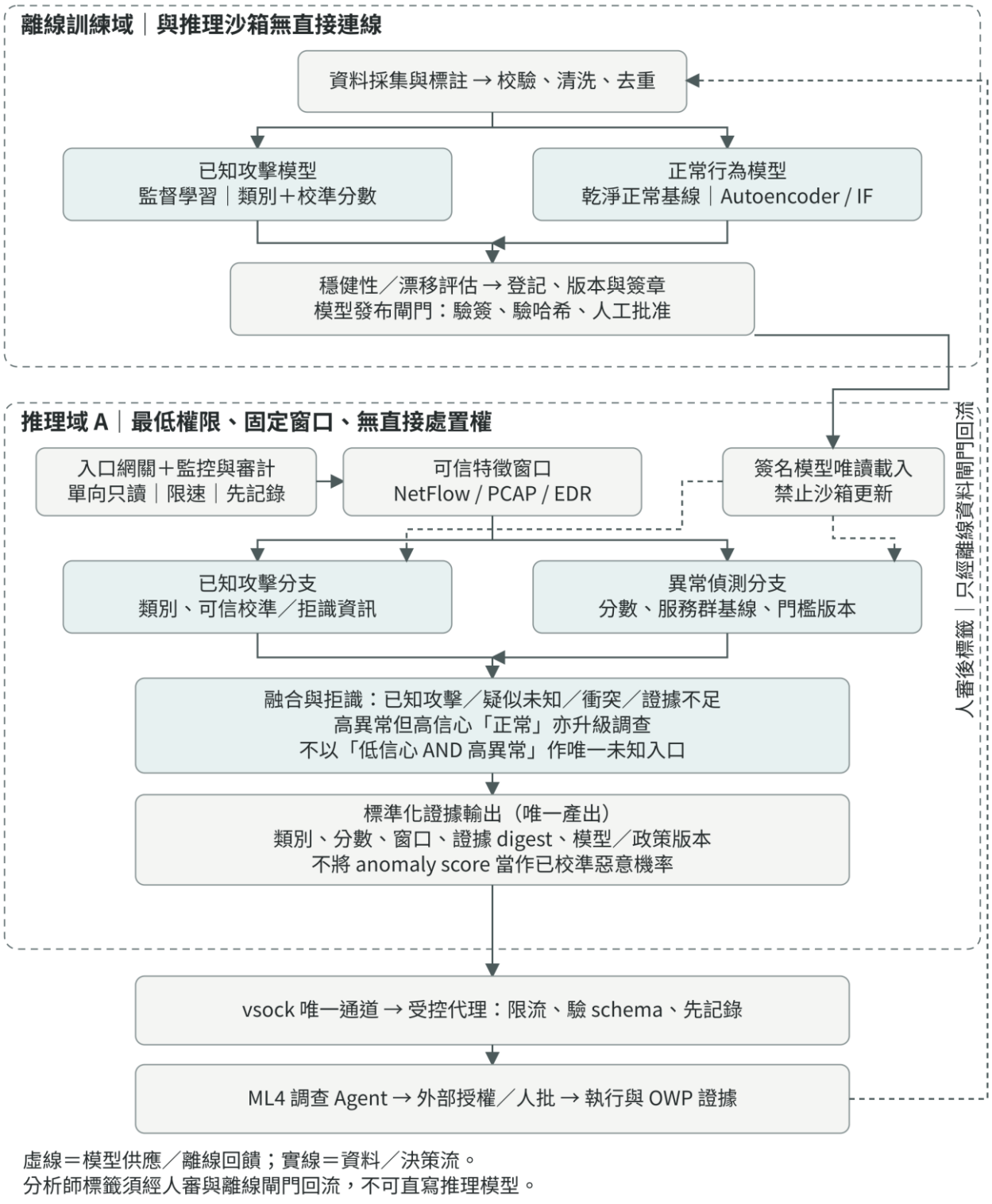


圖 1　dual_model 與調查／處置的職責分離。依 Notion 原架構重繪並修正未知判定；圖中模型、microservice 與通道皆為設計需求，不表示目前已部署。分析師覆核後的標籤只能經離線資料閘門回流。

VI. dual_model 的判定與 Agent 分工

A. 雙分支定義

已知分支 $f_k(x)$ 輸出類別與獨立校準分數，以 Logistic Regression 為基線、樹模型與 MLP 為候選。正常分支 $f_a(x)$ 使用經校驗正常窗口，比較 Autoencoder 與 Isolation Forest。兩者共用相同可用時間點及版本化特徵，避免未來資訊洩漏。

異常分數 $s_a(x)$、服務群門檻 τ_a 與分類分數 $c_k(x)$ 分開保存。99.5 分位只作開發起點，不是最佳門檻或部署 FPR 保證；禁止用測試集調參。

B. 修正唯一 AND 入口

保留原圖「低信心 AND 高異常」路徑，但新增「高信心正常且高異常」衝突及證據不足分支，避免把低信心設為所有未知威脅的必要條件。這是待測的決策修正，不聲稱已提高召回。

表 III　dual_model 多路徑判定與升級。

已知分支／狀態	異常分支	案件輸出／下一步
已知攻擊且證據吻合	高或低	已知可疑案件；依外部風險政策處理。
低信心或拒識	高	疑似未知；Agent 補證據，必須人類檢核。
高信心正常	高	模型衝突；不得直接放行或強行結案。
正常且資料足夠	低	低風險觀察；保留抽查及基線漂移監控。
缺資料／模型失效	任意	UNKNOWN；不能把缺失當正常。

C. Agent 不是第二個授權者

ML4 透過受限唯讀工具關聯證據，輸出 verdict、evidence_ids、missing_evidence、recommended_action；自報信心不是校準機率。模型卡列有工具呼叫與結構化輸出，但無本系統網絡 IDS 實證，須與較小模型在相同預算下比較。[16][13]

日誌與模型回應均不可信。Agent 不能改政策、自批動作、寫訓練標籤或關閉審計。去重、限流及案件佇列獨立運作，以限制告警洪泛造成的資源耗盡。

[13]Mistral AI, Mistral-Large-4-1T-A52B model card, 2026. 廠商能力披露，不屬本研究之網絡 IDS 實證。 https://huggingface.co/mistralai/Mistral-Large-4-1T-A52B

VII. 提出架構二：Agent 逃逸風險控制

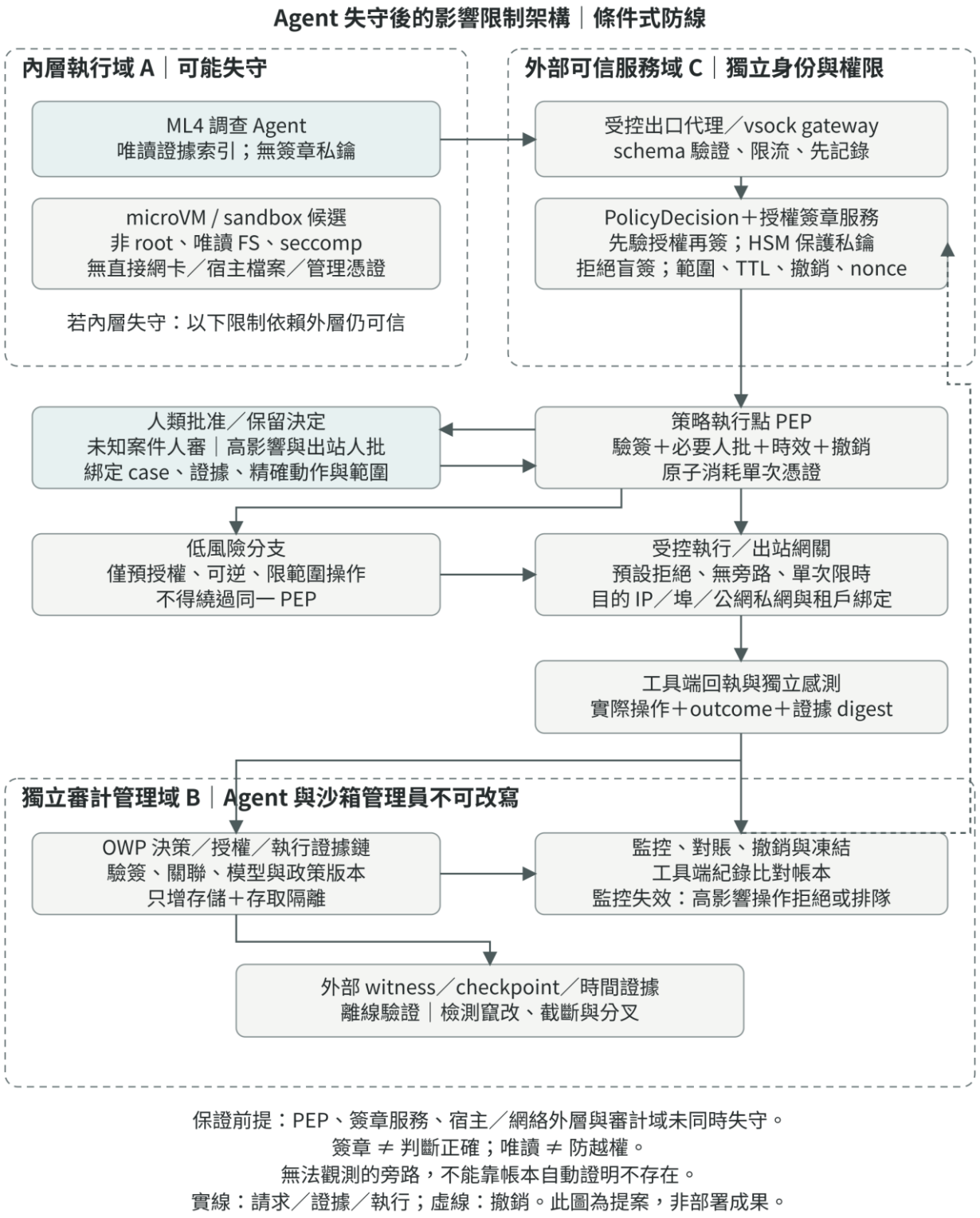


圖 2　假設內層失守的分層影響限制。保留原 Notion 圖的 HSM、單次限時授權、人簽、出口預設拒絕、獨立審計與撤銷，新增簽章前授權、原子防重放、工具端對賬及條件式信任根。

VIII. 外部授權、簽章與證據協定

A. 從 Agent Sign 對接至 OWP 物件

OWP 公開專案以 WorkOrder → CapabilityGrant → PolicyDecision → ActionReceipt → VerificationDecision → AcceptanceDecision 分離任務、能力、事前判定、行動證據、驗證與驗收。本稿以此為對接語義，不把「一個 Agent Sign 欄位」誤當完整授權。OWP 的 VERIFIED 與 ACCEPTED 亦不應等同於偵測判斷一定正確或取得法律認證。[15][14]

建議工作流：凍結案件任務與證據範圍；簽發最小能力；Agent 提出精確動作；外部政策計算 allowed／reserved／denied；reserved 取得綁定證據與參數的人批；PEP 在執行前重新驗證；工具獨立產生回執；驗證者核對證據，最後由具權限的人類驗收或拒絕。

B. 單次授權與簽章不能混淆

Ed25519 提供數碼簽章方法，JCS 提供可重現的 JSON 表示；兩者均不自行定義某次操作是否允許。簽章服務須先驗證外部 PolicyDecision，而不是盲簽 Agent 的任意輸出；HSM 保護私鑰不可匯出，也不能替代這個請求合法性檢查。[13][15][14][16]

SOC 延伸信封至少綁定 schema、case_id、tenant、task_digest、evidence_digest、policy_version、action、resource、destination、issued_at、expires_at、nonce、approval_digest 及 signer identity。這些是本文提議欄位，須與實際 OWP schema 適配，不宣稱原協定已有完全相同欄位。

C. 執行時約束

PEP 驗簽、作用範圍、有效期、撤銷與人批後，以原子操作消耗 nonce，再交由有界執行器處理。多副本須共用一致性狀態；先查再寫的非原子流程可能容許競態。重試以冪等 key 回傳既有結果，不應重複產生副作用；批准後更改目的地、租戶或參數必須重新授權。

出站連線依本專案要求列為 reserved，介面顯示目的 IP、埠、公網／私網與 TTL；若需以網域連線，還須處理解析後地址變化及重新驗證，不讓 UI 顯示的範圍與實際執行不一致。

D. 證據與旁路的邊界

帳本保存決策、批准、執行與結果的關聯摘要，原始敏感內容分開加密存放。哈希鏈配合外部已知 checkpoint 支持篡改或截斷檢測，但無法自行發現完全沒有被記錄的操作；需工具端獨立日誌、網絡遙測與帳本對賬。故使用「可檢測篡改的證據鏈」，不使用無條件「不可抹去」。

IX. 安全性質與道德治理

A. 條件式安全性質

本文定義有效能力 C_eff = C_task ∩ C_grant ∩ C_human ∩ C_runtime。Agent 只能請求操作，不能擴張交集。若所有動作均經不可繞過且正確實作的 PEP，則僅控制 Agent 輸出不足以授權交集以外的動作；這是設計條件下的論證，不是本原型已完成的形式證明。

---

[14] Deng Yier / OpenWorkProof contributors, OpenWorkProof, public project repository. 專案自述與程式設計，不屬獨立效能驗證。 https://github.com/dengyier/OpenWorkProof

[15] A. Rundgren, B. Jordan, and S. Erdtman, JSON Canonicalization Scheme (JCS), RFC 8785, June 2020. Informational RFC. https://www.rfc-editor.org/rfc/rfc8785

[16] S. Josefsson and I. Liusvaara, Edwards-Curve Digital Signature Algorithm (EdDSA), RFC 8032, January 2017. https://www.rfc-editor.org/rfc/rfc8032

簽章有效，只支持指定身份對指定 bytes 的承諾；帳本與外部錨一致，只支持其已承諾歷史的完整性。兩者均不證明感測器未漏收、判斷正確或合法動作沒有造成損害。授權範圍內作惡仍需小範圍配額、可逆操作、速率限制、人工覆核及快速撤銷緩解。

表 IV　把倫理原則轉換為可檢查控制。

原則	系統安排	量測與反面案例
人類自主權	疑似未知案件須人審；高影響與出站需事前批准；人可拒絕。	拒絕／覆寫率、批准前操作數；測試橡皮圖章。
比例與最小權限	以租戶、資源、時間、次數界定能力；優先可逆操作。	錯封影響、撤銷時間；分析授權內濫用。
隱私與用途限制	僅送必要窗口；敏感原文加密分離、權限與期限管理。	調閱量、外傳量、保存期限；摘要推測風險。
問責與可爭議性	證據、政策與批准版本可核對；獨立覆核與簽署申訴。	回溯完整度、翻案率、申訴時間。
公平與可用性	按服務／角色檢查誤報；允許未知而非強制結案。	群組誤報差異、正常任務成功率。

B. 人批不是責任轉嫁

批准介面應同時呈現支持與反證、缺失證據、業務影響、授權範圍及可逆性，而非只展示模型摘要。批准者的點擊不代表承擔全部法律責任；責任仍需依控制能力、組織政策與適用法律判定，本文不作法律結論。

C. 不可變記錄與刪除需求

摘要不必然匿名。可枚舉低熵資料可能被猜測，跨案件摘要亦可能可連結；不可刪儲存不應無限期保留原始個資。研究應明確區分證據承諾、加密原文、存取記錄與刪除政策，並評估刪除後可保留甚麼可驗證性。

X. 實驗設計：偵測、漂移與模型選擇

A. 研究問題與假說

RQ1：雙分支在固定誤報預算下是否改善未見家族召回？RQ2：Agent 是否改善案件證據品質與處理時間？RQ3：在注入／內層失守下，外部 PEP 是否降低未授權實際執行？RQ4：外部見證與工具對賬能否增加竄改及旁路檢測？各自對應 H1–H4，全部未經本文實測。

B. 資料與時間協議

CIC-IDS、UNSW-NB15 等公開資料只作可重現基線，須說明年代、標註與測試床差異；另以授權實驗流量與脫敏 SOC 遙測驗證外部有效性。不得將不同來源混為單一實驗成果。訓練早期、驗證中期、測試較後期；相同 case／campaign、重複 flow 及重疊窗口不得跨集合。

所有 scaler、補值、特徵選擇、校準與門檻只在訓練／驗證集擬合。另做 leave-one-family-out 與跨 site／tenant holdout；若資料不能同時滿足時間與家族切分，分成不同協議報告，不虛稱兩者均達標。家族留出也不得洩漏至門檻調參。

C. 即時特徵與獨立真值

候選特徵包括 byte／packet 方向比例、間隔、連線失敗、主機短窗口統計、程序與登入關聯。JA3／JA4 或 TLS 指紋只作上下文，不當作惡意證明。固定決策時間，禁止使用事後結案文字、未來完整 flow 或後來新增 IOC 聲稱早期檢出。

正常基線須記錄來源與審核依據。漂移觸發隔離樣本及覆核，不能自動把高分事件學成正常；分析師標籤與獨立 IR／事件結果分開保存。Agent 自標答案不得直接作真值或回訓標籤。

表 V　模型基線與消融。所有組別共用可用時間點、資料與工具條件。

組別	配置	要驗證的增量
B0／B1	既有規則；Logistic Regression。	傳統防線與低成本監督基線。
B2／B3	梯度提升樹或 MLP；IF 或 Autoencoder。	監督非線性與正常分支各自效用。
B4	已知＋異常，原 AND 與修正衝突規則。	雙模型及多路徑升級的召回／誤報取捨。
M1／M2	B4＋ML4；B4＋較小 LLM。	固定工具與 token／時間預算的調查效益。
G1／G2	同一模型，固定政策／外部 PEP／人批。	把模型改進與授權改進分開。

XI. 實驗設計：Agent、安全與端到端量測

A. 防禦性測試與控制組

在授權隔離實驗室，以不可信日誌／工具輸出的提示注入、錯誤參數、跨租戶目標、過期批准、撤銷、重放與審計失效測試控制。容器失守測試可預先授予內層控制，以量度外層限制，不必建立可武器化逃逸鏈。不得連接真實客戶網絡、使用真實秘密或向公共第三方測試。

固定模型與任務，分別移除 PEP、資料／控制流隔離、防重放、外部 checkpoint、工具端對賬與人類保留權。消融只在無真實副作用的副本中執行。另設正常任務控制組，避免以拒絕一切獲得表面安全。

表 VI　主要終點、分母與必要解讀。

層面	主要量度	分母／注意事項
偵測	Recall@fixed FPR、事件 Precision、PR-AUC、每日誤報。	正常 flow／window／case 分開定義；非只報 Accuracy。
時間與成本	偵測、調查、批准與實際處置 p50／p95；tokens／案件。	含佇列、工具延遲與人工分鐘；不可只報推理時間。
Agent 效用	正常／受攻擊任務完成率、無證據結論與錯誤結案。	固定任務、工具、攻擊與 token 預算。
授權	未授權請求率、未授權實際執行率、合法錯拒。	請求與真正副作用分開；由工具端觀察判定。
隔離與復原	外層越界、撤銷生效、凍結時間、可用性損害。	指出突破哪一層；零次觀察不等於零風險。
證據	竄改／截斷／分叉／重放檢出；審計覆蓋率。	已知負面控制與獨立對賬；未知狀態不得當通過。

B. 統計與可重現性

預註冊主要終點、門檻選擇與運算預算；按 case／campaign 作 cluster bootstrap 信賴區間，避免把相關封包當獨立樣本。相同案件做配對比較，完整報告種子、家族與環境差異。若無越權成功，報告樣本量與信賴區間，不宣稱可保證零風險。

保存 dataset／model／prompt／policy digest、工具與硬件版本、特徵窗口、候選數與調參預算。獨立觀察者核對工具副作用；LLM 評審只作輔助，不成為越權、外洩或容器突破的唯一真值。本文不預填任何待測數字。

XII. Notion 核對、落地與研究限制

A. 本次實際讀取的材料

已讀取 Docs → openworkproof_AI security 主頁、AI SOC 與 OpenWorkProof 摘要、思路整理、OWP1、相關圖像頁及「AI-IDPS 與 AI Agent 逃逸防禦（2023–2026）」論文子頁。兩張附圖分別涵蓋雙模型訓練／推理與假設 Agent 逃逸後的受控路徑，本稿圖 1、圖 2 依此重繪，而非僅根據先前聊天摘要。

亦讀取頁內 AI-SOC-and-AISandbox-main.zip 與 OpenWorkProof-main.zip。前者 README 與腳本主要示範 Surface Bundle、環境指紋及示例資料；working-demo/README.md 明示缺少真實 ledger／完整簽章，create-signed-demo.py 仍含 placeholder 欄位。故本次快照不足以證明已完成真實 dual_model、ML4 SOC 推理或 HSM／microVM 部署。

另核對本 Project 的 owp-soc-bridge：已有角色簽章、delegated／reserved／denied 政策、帳本與 Merkle checkpoint、覆核綁定及資料閘門；README 與 simulate.py 明確指出全為合成資料及隨機 Agent stub。其私鑰仍在記憶體、witness 為本地 JSONL、注入篩查為啟發式，不能等同 HSM、真實 LLM 或生產隔離。本次不將模擬 label 改善率當作偵測成果。

OWP 附件 capability schema 已有 expires_at、usage_mode；但 owp-soc-bridge/policy.py 的 TTL 主要限制封鎖持續時間，不能當作通用授權有效期或原子 nonce 防重放。不同版本與元件必須分開評估；程式與單元測試只支持受測軟件行為，不等於獨立安全認證或真實逃逸防護。

B. 分階段部署與回退

第一階段 shadow mode：只讀、不產生副作用，建立獨立案件真值與每日負載。第二階段雙簽：疑似未知案件必須人類檢核，高影響操作綁定精確批准。第三階段達到預定安全與容量門檻後，只擴張小範圍可逆動作。誤報、批准延遲或審計缺失超標即回退，並保留既有獨立 IDS／IPS 的已驗證政策。

監控／日誌服務失效時，高影響動作拒絕或排隊；不應因 LLM 無回應而停掉整個既有防禦。部署需量度 GPU／API、狀態儲存、證據保存、工具延遲、人工覆核與分離運維成本，而不是僅以活躍參數估計。

C. 效度限制與投稿界限

本文為敘述綜述與設計方案，沒有新增流量資料或人體研究結果。部分文獻僅核對摘要、會議頁與機構說明，未逐篇重現；預印本、廠商能力披露與作者開源專案不具相同證據等級。不能把 HyperVision 的流量分數、提示注入成功率與容器突破率放在同一排行榜。

正式投稿前須補全文核對、搜尋與排除記錄、資料授權、預註冊、真實實驗、倫理審查適用性判斷、作者貢獻與利益衝突聲明，以及目標 IEEE venue 的 AI 輔助寫作揭露與版型要求。本稿不保證滿足任何特定會議的投稿資格。

XIII. 結論與研究誠信聲明

本研究把核心問題由「哪個模型能防所有 Zero-day」轉為「模型不確定、Agent 被誤導或內層失守時，哪些邊界仍可量測與驗證」。dual_model 對已知與異常模式提供互補訊號；Agent 負責調查而非自授權；外部 PEP 決定可否執行；OWP 將授權、行為、證據與人類驗收關聯。

候選創新在於這些環節的 SOC 整合、條件式安全需求與聯合評估協議，而不是重新宣稱 Autoencoder、HSM、簽章或最小權限的發明。若外層可信根、網絡與審計域共同失守，或存在不可觀測旁路，本文不提供原有安全保證。

研究誠信聲明：所有提議效益均為待驗證假說。本稿未捏造實驗、資料集結果、認證、作者機構或法律合規；原文宣稱與本次核對不一致時，明確保留為目標設計或標記證據不足。原 Notion 筆記未被覆蓋，這份 Word 是可編輯的優化版本。

附記：來源與版本核對

指定 Notion 筆記及附件於 2026-11-01 核對。原始頁面與私有原始資料未另行公開；以下摘要僅識別本次使用的程式附件快照，不構成對其內容正確性的背書。

附件 SHA-256：AI-SOC-and-AISandbox-main.zip = 6a1f84d607091e22cfde34fa6d2d7117fc3054af367d9a5f4b9c3f20e36f86ab；OpenWorkProof-main.zip = ace159e452005f0440b894428d8b3fdec1c14fb99ef6ebda03ea1dbfc45845a9。快照與即時 GitHub 版本可能不同；不將二者混寫為同一次實作狀態。

內部筆記與程式快照是使用者指定材料，不是獨立學術證據；OWP 文件為作者自述，ML4 模型卡為廠商披露。效能與安全性仍須由獨立觀察、負面控制及真實實驗支持。

參考文獻

編號與正文對照；首次引用另附腳註。所有 URL 查閱日期：2026-11-01。

[1] R. Sommer and V. Paxson, “Outside the Closed World: On Using Machine Learning for Network Intrusion Detection,” IEEE Symposium on Security and Privacy, 2010. https://www.icir.org/vern/papers/ml-ids-oakland-10.pdf

[2] D. Arp et al., “Dos and Don’ts of Machine Learning in Computer Security,” USENIX Security, 2022. https://www.usenix.org/conference/usenixsecurity22/presentation/arp

[3] Y. Mirsky, T. Doitshman, Y. Elovici, and A. Shabtai, “Kitsune: An Ensemble of Autoencoders for Online Network Intrusion Detection,” NDSS, 2018; arXiv:1802.09089. https://arxiv.org/abs/1802.09089

[4] C. Fu, Q. Li, and K. Xu, “Detecting Unknown Encrypted Malicious Traffic in Real Time via Flow Interaction Graph Analysis,” NDSS, 2023. https://www.ndss-symposium.org/ndss-paper/detecting-unknown-encrypted-malicious-traffic-in-real-time-via-flow-interaction-graph-analysis/

[5] D. Han et al., “Anomaly Detection in the Open World: Normality Shift Detection, Explanation, and Adaptation,” NDSS, 2023; 年份以 NDSS 2023 議程確認。 https://www.ndss-symposium.org/ndss2023/accepted-papers/

[6] K. Greshake et al., “Not what you’ve signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection,” ACM AISec, 2023; arXiv:2302.12173. https://arxiv.org/abs/2302.12173

[7] Q. Zhan, Z. Liang, Z. Ying, and D. Kang, “InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents,” Findings of ACL, 2024; arXiv:2403.02691. https://arxiv.org/abs/2403.02691

[8] E. Debenedetti et al., “AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents,” NeurIPS Datasets and Benchmarks, 2024; arXiv:2406.13352. https://arxiv.org/abs/2406.13352

[9] E. Debenedetti et al., “Defeating Prompt Injections by Design,” arXiv:2503.18813, 2025, v2. 本稿以所核對預印本為準，不推定後續會議發表狀態。 https://arxiv.org/abs/2503.18813

[10] A. Marchand et al., “Can AI Agents Escape Their Sandboxes? A Benchmark for Evaluating Container Breakout Capabilities,” arXiv:2603.02277, 2026, v3. 本稿按預印本列示。 https://arxiv.org/abs/2603.02277

[11] UK AI Security Institute, “Can AI agents escape their sandboxes? A benchmark for safely measuring container breakout capabilities,” 23 March 2026, 官方技術說明，非另一次獨立實驗。 https://www.aisi.gov.uk/blog/can-ai-agents-escape-their-sandboxes-a-benchmark-for-safely-measuring-container-breakout-capabilities

[12] NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1, January 2023. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.100-1.pdf

[13] A. Rundgren, B. Jordan, and S. Erdtman, JSON Canonicalization Scheme (JCS), RFC 8785, June 2020. Informational RFC. https://www.rfc-editor.org/rfc/rfc8785

[14] S. Josefsson and I. Liusvaara, Edwards-Curve Digital Signature Algorithm (EdDSA), RFC 8032, January 2017. https://www.rfc-editor.org/rfc/rfc8032

[15] Deng Yier / OpenWorkProof contributors, OpenWorkProof, public project repository. 專案自述與程式設計，不屬獨立效能驗證。 https://github.com/dengyier/OpenWorkProof

[16] Mistral AI, Mistral-Large-4-1T-A52B model card, 2026. 廠商能力披露，不屬本研究之網絡 IDS 實證。 https://huggingface.co/mistralai/Mistral-Large-4-1T-A52B